YenkoExpress

UK shops, paid in cedis, delivered in Ghana

Software Requirements Specification

YenkoExpress: UK-to-Ghana shopping platform

System	YenkoExpress
Document	SRS, as-built edition
Version	1.0
Date	7 October 2026
Prepared for	the business owner (product owner) and the development and operations teams
Structure	follows ISO/IEC/IEEE 29148 and the IEEE 830 outline
Generated	12 October 2026

Describes the system as built. This is not legal, tax or customs advice. Generated from the Markdown files in the repository's docs folder, so it is only as current as the date above; regenerate it with `npm run docs:pdf` after documents change.

Contents

1. Introduction

2. Overall description

3. External interface requirements

4. Functional requirements

5. Verification and traceability

6. Non-functional requirements

7. Data requirements

8. Business rules

9. Use cases

10. Constraints, assumptions, dependencies and risks

Appendix A: Requirement status summary

Appendix B: Gaps and future work

Appendix C: Glossary

Appendix D: Revision history

> **How to read this document.** It states what the system *shall* do, and for every requirement it records whether the system **does it today**. Status values: **Implemented**, **Partial** (works with a stated limit) and **Not implemented** (a real gap, listed in Appendix B). Requirements are numbered so they can be traced to tests (section 5). Other documents in this folder explain *how* to use, run and build the system; this one defines *what* it must do.

1. Introduction

1.1 Purpose

This SRS specifies the requirements of **YenkoExpress**, a web system that lets shoppers in Ghana buy goods from UK retailers and pay once in Ghana cedis (GHS), while the operator buys the goods in the UK, ships them to Ghana and has a third-party courier deliver them. It is the reference for deciding whether the system is correct and complete, for planning changes, and for acceptance testing.

1.2 Scope

In scope. A public storefront; customer accounts; carts, checkout and online payment; order tracking; notifications by SMS, WhatsApp and email; a catalogue that fills itself from approved sources; "link orders" for items from shops that are not in the catalogue; an administration console with role-based access for the owner's staff; and the operational machinery to run it (scheduler, health check, audit log).

Out of scope. Physical purchasing, UK warehousing, international freight and the Ghana courier (all done by people outside the software); customs clearance; accounting and tax filing; stock holding (the business holds no stock); a native mobile app; returns and dispute handling beyond cancel and refund; any marketplace of independent sellers.

Benefits. Customers see the full cost in pounds and cedis before paying, pay with local methods, and can follow the order. The operator controls prices and costs, can serve almost any UK shop, and works from a phone.

1.3 Definitions

See Appendix C. Key terms: **catalogue source**, **link order**, **quote**, **effective rate**, **rate card**, **super admin**, **staff account**, **right**.

1.4 References

- This documentation set: Overview, Admin guide, Customer guide, Catalogue sources, Deployment and operations, Architecture, Data model, Security and privacy, Integrations, Testing.
- ISO/IEC/IEEE 29148:2018 and IEEE 830-1998 (document structure).
- Provider documentation for Stripe, Paystack, Flutterwave, Arkesel, Twilio, Meta WhatsApp Cloud API, Resend, Postmark, ExchangeRate-API, Open Exchange Rates the eBay Browse API and the Diffbot Product API (linked from the Integrations page).

1.5 Conventions

- **shall** = mandatory; **should** = expected unless there is a stated reason; **may** = optional.
- IDs: `FR-` functional, `NFR-` non-functional, `BR-` business rule, `DR-` data, `IR-` interface, `UC-` use case.
- **Priority** uses MoSCoW: **M**ust, **S**hould, **C**ould.
- Money is always integer pence (GBP) or pesewas (GHS).

1.6 Overview of the document

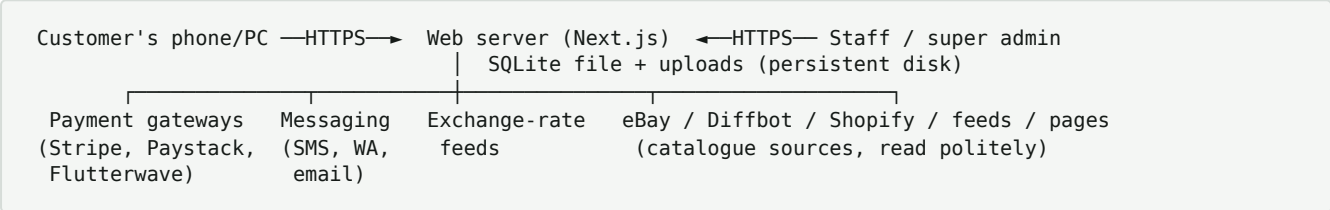
Section 2 describes the product and its users. Section 3 the interfaces. Section 4 the functional requirements, grouped by area. Section 5 how each is verified. Sections 6–8 the quality attributes, data and business rules. Section 9 the main use cases. Section 10 constraints, assumptions and risks.

---

2. Overall description

2.1 Product perspective

A self-contained web application with no dependency on any other system of the business. It depends on **external services** for payments, messaging, exchange rates and catalogue data (section 3.4). It runs as **one server process with a single SQLite database file** on a persistent disk, and is hosted on Render (Frankfurt).



2.2 Product functions (summary)

1. Browse and search a catalogue of UK shops and items with prices in pounds and cedis.
2. Cart, checkout, and online payment in cedis (or pounds where configured).
3. Order lifecycle with tracking, history and notifications.
4. Customer accounts, saved addresses, wishlist, verified-purchase reviews.
5. Link orders: buy an item from any UK shop by pasting its link, with manual or automatic quoting.
6. Catalogue feeding: eBay, Shopify, feeds, sitemap pages, file import, pasted links, with a review queue.
7. Administration: dashboard, orders, customers, requests, catalogue, pricing, shipping, delivery, appearance, integrations, messages, activity log.
8. Staff accounts with roles and fine-grained rights; a super admin that only the developer can use.
9. Operations: scheduler, health check, cron endpoints, encrypted secrets, backups guidance.

2.3 User classes and characteristics

Class	Description	Skills and access
Customer (shopper)	Person in Ghana ordering for themselves. May be a first-time online buyer, usually on a phone with a mobile-data connection.	Needs simple, fast, low-bandwidth pages. Signs in with phone or email.
Visitor	Browses or looks up an order without an account.	No sign-in.
Staff	The owner's employees, each with their own account and only the rights granted (for example customer support, operations, catalogue, finance).	Non-technical. Often on a phone.
Super admin	The developer. Signs in with a server-held password. Can do everything and is the only one who manages staff.	Technical.
Payment gateway / messaging provider	External systems that call the webhook endpoints or are called by the system.	Machine.

Class	Description	Skills and access
Scheduler	The in-process timer and external cron callers.	Machine.

2.4 Operating environment

- **Server:** Node.js 22, Linux container (Docker), one instance, persistent disk, HTTPS terminated by the host.
- **Clients:** current versions of Chrome, Edge, Firefox and Safari on desktop; Chrome and Safari on Android and iPhone; viewport widths from 320 px.
- **Database:** SQLite (single file, write-ahead logging).

2.5 Design and implementation constraints

- **DC-1** One running instance only (single-writer database, in-memory throttles, in-process scheduler).
- **DC-2** Must run on a host with a persistent disk; serverless hosts are not supported.
- **DC-3** Card data shall never be handled by the system; payment uses gateway-hosted pages.
- **DC-4** The importer shall obey `robots.txt` and shall never evade access controls (see FR-CAT-30 to FR-CAT-33).
- **DC-5** Technology: Next.js 16 (App Router), React 19, TypeScript, Tailwind CSS 4, better-sqlite3, zod.
- **DC-6** All money in integer minor units; one pure pricing module used everywhere.

2.6 Assumptions and dependencies

- **A-1** The operator has accounts with at least one payment gateway before taking orders.
- **A-2** Customers have a Ghana mobile number; messages are delivered in English.
- **A-3** The operator has permission, or a lawful basis, to show the catalogue data and images it imports.
- **A-4** UK retailers accept orders delivered to a UK address controlled by the operator.
- **A-5** The operator handles customs duty, VAT and consumer-law obligations outside the software.
- **D-1** Payment, messaging, exchange-rate and eBay services are available and their keys valid.
- **D-2** The host provides HTTPS, a persistent disk and a stable public address (`APP_URL`).

---

3. External interface requirements

3.1 User interfaces

ID	Requirement	Pri	Status	Verified by
IR-UI-01	The storefront shall be usable on phone, tablet and desktop, with no page wider than the screen at widths from 320 px.	M	**Implemented**	E2E "the shop fits a phone"
IR-UI-02	The admin shall be usable on a phone: a Menu button replaces the sidebar, wide lists become labelled cards, no sideways scrolling.	M	**Implemented**	E2E "the admin fits a phone"
IR-UI-03	Form fields shall use text of at least 16 px on phones (to prevent iPhone zoom) and interactive targets shall be at least 44 px tall.	S	**Implemented**	E2E (field size check); inspection
IR-UI-04	Every price shall be shown in **both pounds and cedis** on the product, cart and checkout pages.	M	**Implemented**	Inspection; E2E checkout total

ID	Requirement	Pri	Status	Verified by
IR-UI-05	The look shall be themeable: the admin chooses one of 15 colour themes that applies to the whole shop.	S	**Implemented**	`themes.test.ts` ; E2E "admin colour theme reaches the storefront"
IR-UI-06	A prominent paste-a-link entry shall be available on the home page, in the header, in the search box and as a phone tab.	S	**Implemented**	E2E "paste-a-link box…"
IR-UI-07	Images that fail to load shall fall back to a category icon (items) or the first letter on the shop colour (shop logos).	S	**Implemented**	Inspection
IR-UI-08	Interface text shall be in plain English suitable for first-time online buyers.	S	**Implemented**	Inspection
IR-UI-09	Screens shall meet WCAG 2.1 AA for colour contrast, labels, keyboard use and focus.	S	**Partial (labels, focus, keyboard and landmarks are implemented; no formal audit)**	Inspection

3.2 Hardware interfaces

None. The system is a web application and uses no special hardware.

3.3 Software interfaces (internal)

- **IR-SW-01** Database: SQLite through `better-sqlite3` , schema in `src/lib/schema.ts` .
- **IR-SW-02** Browser storage: a cart cookie, a customer session cookie, an admin session cookie, a delivery-area cookie, and a local list of recently viewed items. No third-party cookies or trackers.

3.4 Communication and external-service interfaces

ID	Interface	Direction	Requirement	Status
IR-EX-01	**Stripe**	out and webhook in	Create hosted checkout in GBP or GHS; receive signed events (`checkout.session.*`).	**Implemented**
IR-EX-02	**Paystack**	out and webhook in	Create hosted checkout in GHS; verify and receive signed events.	**Implemented**
IR-EX-03	**Flutterwave**	out and webhook in	Create hosted payment in GHS; webhook authenticated by shared hash and re-verified with the gateway.	**Implemented**
IR-EX-04	**Arkesel**, **Twilio**	out	Send SMS (Arkesel: branded sender name).	**Implemented**
IR-EX-05	**Meta WhatsApp Cloud API**, **Twilio**	out	Send approved template messages.	**Implemented**
IR-EX-06	**Resend**, **Postmark**	out	Send transactional email (text and HTML).	**Implemented**
IR-EX-07	**ExchangeRate-API**, **Open Exchange Rates**	out	Fetch the GBP to GHS market rate.	**Implemented**
IR-EX-12	**Diffbot Product API**	out	Read each listed product page by token; only prices in GBP; stop on bad token, no credits or rate limit.	**Implemented**
IR-EX-08	**eBay Browse API**	out	OAuth client-credentials, search UK fixed-price listings in GBP.	**Implemented**
IR-EX-09	**Shop websites and feeds**	out	Fetch feeds, sitemaps, Shopify `/meta.json` and `/products.json` , WooCommerce `/wp-json/wc/store/v1/products` , and product pages, subject to FR-CAT-30 to FR-CAT-33.	**Implemented**

ID	Interface	Direction	Requirement	Status
IR-EX-10	**Inbound endpoints**	in	`/api/webhooks/{stripe,paystack,flutterwave}`; `/api/cron/{messages,fx,ingest}` (bearer secret); `/api/health`.	**Implemented**
IR-EX-13	**Sign in with Google, Facebook and Apple**	out	OpenID Connect and OAuth 2.0 authorisation-code flows over HTTPS; Google and Apple identify the person by an ID token from the token endpoint, Facebook by its Graph profile.	**Implemented**
IR-EX-11	**All outbound calls**	out	Shall use HTTPS where the provider offers it and shall have time and size limits (verified by inspection and `net.test.ts`).	**Implemented**

---

4. Functional requirements

Each table lists the requirement, its priority (M/S/C), its status, and how it is verified. "E2E" means a step of the browser run (`npm run e2e`); file names refer to unit tests in `src/lib`.

4.1 Browsing and search (FR-BRW)

ID	Requirement	Pri	Status	Verified by
FR-BRW-01	The system shall show a home page with featured banners, a paste-a-link entry, departments, new arrivals, best sellers, and recently viewed items.	M	**Implemented**	E2E "home renders deals shelf"
FR-BRW-02	The system shall list shops and show a page per shop with its logo, description, department and items, filterable by item category and sortable.	M	**Implemented**	E2E; `browse.test.ts`
FR-BRW-03	The system shall show a page per department (the category a shop is filed under) listing its items and shops, with an icon chosen from the department name.	S	**Implemented**	`department-icons.test.ts`
FR-BRW-04	The system shall offer text search with suggestions of items, shops and departments while typing (at least 2 characters), rate-limited to 120 requests per minute per visitor.	M	**Implemented**	E2E "search suggests products as you type"; `discovery.test.ts`
FR-BRW-05	A pasted web address in the search box shall be recognised and sent to the link flow instead of a text search.	S	**Implemented**	E2E "search box recognises pasted links"
FR-BRW-06	Results shall be filterable by department, shop, item category, price range (typed in cedis), and sortable by featured, price low-to-high, price high-to-low, best rated and newest, 24 per page.	M	**Implemented**	`browse.test.ts`
FR-BRW-07	Invalid or hostile query parameters shall fall back to safe defaults.	M	**Implemented**	`browse.test.ts`
FR-BRW-08	The product page shall show photos (or a fallback), price in pounds and cedis, size/colour options, quantity, the shop, a link to the item on the shop's own website, reviews and rating, related items from the same shop, a wishlist button and a share-on-WhatsApp link.	M	**Implemented**	E2E; inspection
FR-BRW-09	The product page shall show "what it costs to your door" for the chosen delivery area and shipping method.	M	**Implemented**	`pricing.test.ts`; inspection
FR-BRW-10	The visitor shall be able to choose a delivery area that is remembered (cookie; for signed-in customers also saved as their default) and used for "to your door" prices across the shop.	S	**Implemented**	Inspection

ID	Requirement	Pri	Status	Verified by
FR-BRW-11	Only items marked active, of shops marked shown, shall appear to customers.	M	**Implemented**	`discovery.test.ts` ("hides products from inactive shops")
FR-BRW-12	The system shall make no discount claims: no percentage-off tags, "was" prices, savings amounts, "deal" labels or countdowns. Prices a source reports as a "was" or list price shall not be stored on items or shown.	M	**Implemented**	`discovery.test.ts` ("no discount claims"); `run.test.ts`

4.2 Cart (FR-CRT)

ID	Requirement	Pri	Status	Verified by
FR-CRT-01	A visitor shall be able to add an item, choosing every option (such as size and colour) it requires, without signing in.	M	**Implemented**	E2E "added 2 trainers to the cart"
FR-CRT-02	The same item with the same options shall merge into one line; quantity shall be limited to 1 to 20 per line.	M	**Implemented**	Inspection (`cart.ts`)
FR-CRT-03	The cart shall persist for the visitor through a random token cookie and survive sign-in.	M	**Implemented**	E2E "registered and returned to checkout with the cart intact"
FR-CRT-04	The cart shall show line prices and totals in cedis and pounds, and the progress towards the minimum order.	M	**Implemented**	E2E "cart total"
FR-CRT-05	A visitor shall be able to change quantity, remove a line, and open a cart drawer from any page; a cart count shall show in the header.	M	**Implemented**	E2E
FR-CRT-06	The cart shall price from live data on every view; the browser's figures shall never be trusted.	M	**Implemented**	`pricing.test.ts` ; `admin.test.ts` ("prices from live settings")

4.3 Pricing (FR-PRC)

ID	Requirement	Pri	Status	Verified by
FR-PRC-01	The customer total shall equal items + service charge + shipping to Ghana + delivery in Ghana.	M	**Implemented**	`pricing.test.ts`
FR-PRC-02	Item prices shall be converted at the effective rate = admin rate × (1 + markup%).	M	**Implemented**	`pricing.test.ts`
FR-PRC-03	The service charge shall be configurable as a percentage with a minimum, a flat amount, or tiered bands on the item total, and shall be shown on its own line.	M	**Implemented**	`pricing.test.ts` ; `admin-parse.test.ts`
FR-PRC-04	Shipping shall be taken from the chosen method's rate card: weight brackets, a charge per extra kilogram above the largest bracket, and a minimum charge, by chargeable weight (greater of actual and volumetric where known).	M	**Implemented (items carry actual weight only)**	`pricing.test.ts`
FR-PRC-05	Delivery shall be a flat fee per delivery area.	M	**Implemented**	`pricing.test.ts`
FR-PRC-06	The system shall enforce a minimum order value (items only, in pounds) set by the admin; default £10.	M	**Implemented**	`admin.test.ts` ("enforces the minimum order")
FR-PRC-07	One pure function shall price the product page, cart, checkout and the stored order, so the displayed amount equals the charged amount.	M	**Implemented**	`pricing.test.ts` ; E2E "checkout total matches cart"

ID	Requirement	Pri	Status	Verified by
FR-PRC-08	An order shall store the rate, markup and every amount at the time it is placed; later setting changes shall not alter it.	M	**Implemented**	`admin.test.ts` ; schema inspection
FR-PRC-09	The admin shall see a worked example of what customers pay while editing pricing.	C	**Implemented**	Inspection
FR-PRC-10	Import duty and taxes charged in Ghana shall not be included, and the system shall say so at checkout.	M	**Implemented**	Inspection

4.4 Customer accounts (FR-ACC)

ID	Requirement	Pri	Status	Verified by
FR-ACC-01	A visitor shall be able to register with name, a phone number (stored in international form), an optional email and a password (at least 8 characters; common or personal passwords refused).	M	**Implemented**	`customers.test.ts` ; `password.test.ts` ; E2E
FR-ACC-02	A customer shall sign in with phone or email and password. Passwords shall be hashed with scrypt; an unknown identifier shall take the same time as a wrong password.	M	**Implemented**	`customers.test.ts` ; `password.test.ts`
FR-ACC-03	Sessions shall last 30 days, be stored hashed, and be revocable; a customer shall be able to sign out other devices.	M	**Implemented**	`customer-session.test.ts`
FR-ACC-04	A customer shall be able to reset a forgotten password with a one-time link valid for 60 minutes, sent by email or SMS; using it shall end all other sessions.	M	**Implemented**	`customers.test.ts`
FR-ACC-05	A customer shall be able to edit their profile, change their sign-in details and password, and choose SMS, email and WhatsApp notifications.	M	**Implemented**	`customers.test.ts`
FR-ACC-06	A customer shall be able to keep up to 10 saved addresses, one of them default, each with recipient, phone, delivery area, address and landmark.	S	**Implemented**	`customers.test.ts`
FR-ACC-07	A customer shall have a wishlist and see their order history, per-order tracking, an updates feed (with unread marking), live tracking of the latest order, and "buy again".	S	**Implemented**	`account-orders.test.ts` ; E2E "wishlist", "order appears in the account"
FR-ACC-08	A customer shall be able to delete their account. Reviews shall remain shown as "Former customer", link requests shall be detached, orders shall be kept without an account link.	S	**Implemented**	`customers.test.ts`
FR-ACC-09	Staff shall be able to disable and re-enable a customer account (signing the customer out everywhere) and create a one-time reset link, without affecting orders.	S	**Implemented**	E2E "every admin page loads"; `customers.test.ts`
FR-ACC-12	A customer shall be able to sign in or sign up with Google, Facebook or Apple when the shop owner has set that provider up and switched it on, and to connect further providers to an existing account.	S	**Implemented**	`social.test.ts` ; E2E "social sign-in"
FR-ACC-13	An existing account shall be matched to a provider sign-in only by the provider's own id, or by an email address the provider itself reports as verified (Google, Apple). An unverified email (Facebook), a phone number or a name shall never connect or take over an account.	M	**Implemented**	`social.test.ts`

ID	Requirement	Pri	Status	Verified by
FR-ACC-14	Each provider sign-in attempt shall be single-use, expire in 10 minutes, be tied to the browser that began it by a cookie (SameSite=None where Apple's cross-site form post requires it), carry a state value, a nonce and, for Google, a PKCE challenge, and refuse an ID token of another issuer, audience, expiry or nonce.	M	**Implemented**	`social.test.ts` ; E2E "social sign-in"
FR-ACC-15	A first-time provider sign-in shall ask for a phone number before the account is created, because deliveries are arranged by phone; a phone number already on an account shall not be linked automatically.	M	**Implemented**	`social.test.ts`
FR-ACC-16	The shop shall publish a privacy policy (`/privacy`), terms of service (`/terms`) and data-deletion instructions (`/data-deletion`), linked from every page's footer, using the business name and contact email set by the owner.	M	**Implemented**	E2E "the privacy policy, terms and data-deletion pages"
FR-ACC-17	A customer whose account was made with Google, Facebook or Apple and who has not chosen a password shall be able to delete their account by typing DELETE while signed in; a customer with a password shall be asked for it.	M	**Implemented**	`social.test.ts`
FR-ACC-10	Registration shall verify the phone number or email (for example with a one-time code).	S	**Not implemented**	–
FR-ACC-11	Sign-in, sign-up and reset attempts shall be rate-limited (sign-in 15 per place and 6 per account per 15 minutes; sign-up 10 per hour; reset 6 per place and 3 per account per hour).	M	**Implemented**	`throttle.test.ts`

4.5 Checkout and orders (FR-ORD)

ID	Requirement	Pri	Status	Verified by
FR-ORD-01	Checkout shall require a signed-in customer and send a guest to sign in, returning to checkout with the cart intact.	M	**Implemented**	E2E "checkout asks a guest to sign in"
FR-ORD-02	Checkout shall collect recipient name, phone for the rider, optional email, delivery area, shipping method, address (min 5 characters), optional landmark and note, and the customer's notification choices, validating each on the server.	M	**Implemented**	`admin.test.ts` ; E2E
FR-ORD-03	The customer shall be able to choose a saved address and optionally save a new one.	S	**Implemented**	Inspection
FR-ORD-04	Placing an order shall create it with status *Awaiting payment*, a unique number `UKG-YYYY-NNNNNN` , a unique payment reference, its lines and a first history event, in one transaction.	M	**Implemented**	`admin.test.ts` ("creates an order that is paid exactly once")
FR-ORD-05	An order shall have one of these statuses: Awaiting payment, Payment received, Buying from the UK shop, Bought from the UK shop, Received at our UK address, On its way to Ghana, Clearing customs in Ghana, Out for delivery, Delivered, Cancelled, Refunded.	M	**Implemented**	`order-status.test.ts`
FR-ORD-06	Only a confirmed payment shall set *Payment received*; staff shall not be able to mark an order paid.	M	**Implemented**	`order-status.test.ts` ; `admin.test.ts`
FR-ORD-07	Staff shall be able to move an order one step forward at a time, cancel it up to *Buying from the UK shop*, and mark a paid and cancelled order *Refunded*; other moves shall be refused.	M	**Implemented**	`order-status.test.ts`

ID	Requirement	Pri	Status	Verified by
FR-ORD-08	Every status change shall be recorded as an event with an optional note, which the customer sees.	M	**Implemented**	E2E "customer sees the status change"
FR-ORD-09	Staff shall be able to add and remove tracking entries at four stages (UK shop dispatch, received at our UK address, UK-to-Ghana shipment, delivery in Ghana), each with carrier, reference, link and note, visible to the customer.	S	**Implemented**	Inspection; E2E (tracking present)
FR-ORD-10	A visitor shall be able to look up an order with its number and the phone or email used, with failures rate-limited (8 per 15 minutes).	S	**Implemented**	`admin.test.ts` ; `throttle.test.ts`
FR-ORD-11	Staff shall be able to list orders (search by number, name or phone; filter by status), open one, and see items, delivery details, price breakdown, payments and history.	M	**Implemented**	E2E "every admin page loads"
FR-ORD-12	Staff shall be able to record the real cost of an order (shop price, UK delivery, purchase rate, freight, Ghana delivery, payment fees, other) and see the margin.	S	**Implemented**	`admin-logic.test.ts`
FR-ORD-13	Staff with the right shall be able to export orders as CSV, with the action logged.	S	**Implemented**	E2E "support account cannot download"; inspection
FR-ORD-14	A customer shall be able to cancel their own order before it is bought.	C	**Not implemented (customers ask; staff cancel)**	–
FR-ORD-15	The system shall issue a receipt or invoice document for each paid order.	S	**Not implemented (the order page shows the breakdown)**	–
FR-ORD-16	The system shall limit orders to 10 per visitor per hour.	M	**Implemented**	Inspection

4.6 Payments (FR-PAY)

ID	Requirement	Pri	Status	Verified by
FR-PAY-01	The system shall support Stripe, Paystack and Flutterwave; any number may be switched on and the customer chooses among those on.	M	**Implemented**	`payments.test.ts`
FR-PAY-02	The customer shall pay on the gateway's hosted page; the system shall never receive or store card data.	M	**Implemented**	Inspection
FR-PAY-03	The charge amount and currency shall be taken from the stored order (cedis for Paystack and Flutterwave; pounds or cedis for Stripe by setting).	M	**Implemented**	`payments.test.ts`
FR-PAY-04	An order shall be marked paid only when the gateway confirms success and the **amount and currency match** the order. A mismatch shall not mark it paid and shall be flagged to staff.	M	**Implemented**	`payments.test.ts`
FR-PAY-05	Webhook signatures shall be verified on the raw body; for shared-secret gateways the payment shall be re-checked with the gateway; each event shall be applied once; bodies over 1 MB shall be refused; processing errors shall return 500 so the gateway retries.	M	**Implemented**	`payments.test.ts`
FR-PAY-06	The customer's return from the gateway shall also be confirmed with the gateway (rate-limited).	M	**Implemented**	`payments.test.ts`

ID	Requirement	Pri	Status	Verified by
FR-PAY-07	A failed or abandoned payment shall leave the order awaiting payment so the customer can retry from the payment page.	M	**Implemented**	Inspection
FR-PAY-08	A pretend payment page shall exist only when explicitly enabled and never by default in production.	M	**Implemented**	E2E (uses it); inspection
FR-PAY-09	The system shall start a refund with the gateway.	C	**Not implemented (staff refund in the gateway dashboard, then mark *Refunded*)**	–

4.7 Notifications (FR-MSG)

ID	Requirement	Pri	Status	Verified by
FR-MSG-01	The system shall send order updates by SMS, WhatsApp and email through providers chosen and switched on by the admin.	M	**Implemented**	`outbox.test.ts`
FR-MSG-02	Which statuses use which channels shall be configurable (defaults: all channels for payment received, UK address, shipped, out for delivery, delivered, cancelled, refunded; email only for buying, bought, customs; none for awaiting payment).	S	**Implemented**	`outbox.test.ts`
FR-MSG-03	A message shall be sent only if the channel's provider is on and configured, the rule allows it, the customer chose that channel, and a valid address exists.	M	**Implemented**	`outbox.test.ts`
FR-MSG-04	Messages shall be queued in an outbox, sent immediately, and retried up to three times; failures shall wait for staff with the reason.	M	**Implemented**	`outbox.test.ts`
FR-MSG-05	Phone numbers shall be normalised to international form (Ghana `0…` to `+233…`).	M	**Implemented**	`phone.test.ts`
FR-MSG-06	The system shall send password-reset messages and link-order quote messages (email first, then SMS).	M	**Implemented**	`templates.test.ts` ; `link-orders.test.ts`
FR-MSG-07	Staff shall see a log of messages with status and error, recipients partly hidden, and be able to retry or send queued messages now.	S	**Implemented**	E2E (page loads); inspection
FR-MSG-08	WhatsApp messages shall use approved template variables (name, order number, update).	M	**Implemented**	`outbox.test.ts`

4.8 Reviews and wishlist (FR-REV)

ID	Requirement	Pri	Status	Verified by
FR-REV-01	Only a customer with a **delivered** order for the item shall be able to review it, once.	M	**Implemented**	`discovery.test.ts` ("reviews")
FR-REV-02	A review shall have a rating of 1 to 5, an optional title (up to 100 characters) and body (up to 2,000), shown as first name and last initial.	M	**Implemented**	Inspection
FR-REV-03	Staff shall be able to hide or publish reviews; only published reviews count towards the rating and appear.	S	**Implemented**	`discovery.test.ts` ("reviews")
FR-REV-04	Signed-in customers shall be able to save items to a wishlist and see it in their account.	S	**Implemented**	E2E "wishlist saves an item"

4.9 Link orders (FR-LNK)

ID	Requirement	Pri	Status	Verified by
FR-LNK-01	A visitor shall be able to submit a product link from the home page box, the header, the search box and a request page, with quantity, size/colour notes and item type; the system shall attach the request to the signed-in customer.	M	**Implemented**	E2E "a link request is quoted, paid for…"
FR-LNK-02	The system shall read the link's name and price when the shop's `robots.txt` allows, show the price in pounds and cedis, and say when an item is already listed.	S	**Implemented**	`run.test.ts` ; E2E (faked answer)
FR-LNK-03	A found link shall continue in one step to the customer's price and payment; the price shall be read again on the server and never taken from the browser.	S	**Implemented**	`link-submit.test.ts` ; E2E "a found link goes straight…"
FR-LNK-04	Staff shall be able to **quote** a request with the UK price of one item, its weight, a validity period (1 to 30 days) and a note; the quote shall create a private pay link that is messaged to the customer and shown to staff. A quote can be changed until the customer orders without changing the link.	M	**Implemented**	`link-orders.test.ts` ; E2E
FR-LNK-05	The pay link shall use a long random token, show the full cost, require the customer to be signed in, expire after its validity, and create **at most one order**.	M	**Implemented**	`link-orders.test.ts`
FR-LNK-06	Paying a quote shall create an ordinary order (same pricing, minimum order, statuses, tracking, messages, refunds and costs) linked back to the request.	M	**Implemented**	`link-orders.test.ts`
FR-LNK-07	The system shall quote by itself, when the admin allows it, from (a) the price read from the shop's own page (default on) or (b) the customer-typed price plus an admin-set safety margin (default off), only up to an admin-set limit per item (default £150), using a weight from an admin-set item-type list. Otherwise the request shall wait for staff.	S	**Implemented**	`link-auto.test.ts` ; E2E "automatic quotes…"
FR-LNK-08	A link order shall show staff how the price was found (shop page, customer-typed plus margin, or staff-quoted) as a reminder to verify before buying.	S	**Implemented**	Inspection
FR-LNK-09	Customers shall see their link requests and their state (checking, price ready, expired, ordered) in their account.	S	**Implemented**	E2E
FR-LNK-10	Link requests shall be rate-limited to 6 per visitor per hour and previews to 12 per 10 minutes.	M	**Implemented**	Inspection
FR-LNK-11	The system shall verify the real shop price automatically at purchase time.	C	**Not implemented (staff verify by hand; a banner reminds them)**	–
FR-LNK-12	The system shall recognise Amazon product links (including short links and shared text) by their ASIN, turn an Amazon UK link into its clean `amazon.co.uk/dp/ASIN` form, and refuse other Amazon stores with a message offering the UK link. The shop shall never request an Amazon page itself; the customer reads the price on Amazon and types it, and staff verify before buying.	S	**Implemented**	`amazon-links.test.ts` ; E2E "ordering from Amazon UK…"
FR-LNK-13	The search page shall offer a hand-off to Amazon UK's own search for the same words, and an Amazon page (`/amazon`) shall explain the steps and offer a one-click bookmarklet that opens the request form pre-filled from the page the customer is viewing.	S	**Implemented**	E2E

ID	Requirement	Pri	Status	Verified by
FR-LNK-14	The shop shall be installable as a phone app and appear in the phone's Share menu (web app manifest with a share target), so a customer can share an Amazon product from the Amazon app straight into a request.	C	**Implemented**	E2E
FR-LNK-15	A customer shall be able to request an item by describing it (at least 3 characters) without a link. Such a request shall never be quoted automatically; staff shall be offered searches for it and can attach the link they find when quoting.	S	**Implemented**	`link-submit.test.ts` ; E2E "an item described in words…"

4.10 Catalogue management (FR-CAT)

ID	Requirement	Pri	Status	Verified by
FR-CAT-01	Staff with the right shall be able to create, edit, show/hide and delete shops (name, department, tagline, description, website, colour, order, logo by upload or link). Deleting a shop shall remove its items, sources and cart/wishlist entries but never alter placed orders; confirmation shall be required.	M	**Implemented**	`shop-delete.test.ts` ; `shop-logo.test.ts` ; E2E
FR-CAT-02	Staff shall be able to create and edit items (name, brand, category, description, UK price, weight, size/colour options, source link, photo upload or link, shown/hidden).	M	**Implemented**	`admin.test.ts` ; E2E
FR-CAT-03	Uploaded images shall be accepted by file content (JPEG, PNG, WebP, GIF), up to 4 MB, stored under random names, and served with a fixed type, `nosniff` and a sandbox policy.	M	**Implemented**	`uploads.test.ts` ; E2E "fake images are refused"
FR-CAT-04	A new database shall contain only the shop **eBay UK**; made-up sample data shall be created only for tests or when explicitly enabled.	M	**Implemented**	`seed.test.ts`
FR-CAT-10	The system shall support catalogue sources of these kinds: product feed (CSV/JSON), eBay API, Diffbot Product API, Shopify shop, WooCommerce shop, shop website (sitemap and product pages), file import, pasted links.	M	**Implemented**	`run.test.ts` , `ebay.test.ts` , `shopify.test.ts` , `woocommerce.test.ts` , `file-import.test.ts`
FR-CAT-11	A source shall not be switched on until staff confirm they have checked the shop's terms or hold a licence.	M	**Implemented**	`run.test.ts` ; E2E "sources need confirmed permission"
FR-CAT-12	Staff shall be able to preview a source without saving, run it now, switch it on or off, set its schedule and rules, and remove it keeping or removing its products.	M	**Implemented**	`run.test.ts` ; E2E
FR-CAT-13	The system shall run due sources automatically (built-in scheduler, 10-minute tick; each source default every 24 hours) or via an external cron endpoint.	M	**Implemented**	`run.test.ts` (due sources); inspection
FR-CAT-14	New items shall be published automatically unless held; changes of price, stock or photo shall update live items; items missing from a complete feed shall be hidden only if at least half remain; items not refreshed within the source's stale window (default 14 days) shall be hidden.	M	**Implemented**	`run.test.ts`
FR-CAT-15	Items with a price under 50p or over £10,000, a name under 3 characters, a name that looks like a warranty, protection plan or fee rather than a product, no link back, or a price move above the source's limit (default 40%) shall be held for staff review; staff shall be able to approve or reject singly or in bulk.	M	**Implemented**	`run.test.ts`

ID	Requirement	Pri	Status	Verified by
FR-CAT-16	Only prices in pounds shall be accepted.	M	**Implemented**	`parse.test.ts` ; `shopify.test.ts`
FR-CAT-17	Feed addresses (which often hold keys) shall be stored encrypted and shown truncated.	M	**Implemented**	`run.test.ts` ; `secrets.test.ts`
FR-CAT-18	A Shopify or WooCommerce source shall read the shop's public product list only if `robots.txt` allows, the shop's currency is GBP, and the shop is a Shopify (or, for WooCommerce, a Store API) shop; sizes and colours shall become item options; products whose variants differ in price shall be skipped.	M	**Implemented**	`shopify.test.ts` , `woocommerce.test.ts`
FR-CAT-19	A file-import source shall accept an uploaded CSV or JSON, apply the same checks as a feed, update on re-upload, and never remove products.	S	**Implemented**	`file-import.test.ts` ; E2E
FR-CAT-20	An eBay source shall sign in with the admin's keys, search each listed query, accept only new, fixed-price, UK-located GBP listings, and never treat a missing result as removal.	M	**Implemented**	`ebay.test.ts`
FR-CAT-21	A Diffbot source shall read each listed product page through Diffbot's Product API using the admin's token, check the shop's `robots.txt` first and send nothing for a disallowed page, accept only prices in GBP, stop on a bad token, exhausted credits or rate limit, and never treat the list as complete.	M	**Implemented**	`diffbot.test.ts`
FR-CAT-30	The importer shall identify itself honestly (`ShopCatalogBot` , with this site's address in its user agent) and obey `robots.txt` and any `Crawl-delay` , with at least 2 seconds between requests to one shop.	M	**Implemented**	`net.test.ts`
FR-CAT-31	The importer shall fetch only http/https on ports 80 and 443, never reach private or internal addresses (also checked at name resolution), follow at most three redirects (each re-validated), and enforce size and time limits.	M	**Implemented**	`net.test.ts`
FR-CAT-32	When a shop answers 401, 403, 429 or 451, or shows a verification page, the importer shall stop, pause that source for 24 hours and tell staff.	M	**Implemented**	`net.test.ts` ; `run.test.ts`
FR-CAT-33	The importer shall never evade a block: no changed identity, rotating addresses, or CAPTCHA solving.	M	**Implemented (by design)**	Inspection; `net.test.ts`
FR-CAT-34	Only one run per source at a time (lock expiring after 30 minutes).	M	**Implemented**	`run.test.ts`

4.11 Administration (FR-ADM)

ID	Requirement	Pri	Status	Verified by
FR-ADM-01	The dashboard shall show, for the last 7, 30 or 90 days, revenue, orders, average order, service charge earned, new customers (each compared with the previous period), sales by day, orders in progress by status, revenue composition, margin, top shops, items and areas, customers, the exchange rate, integrations status, latest orders and recent activity.	M	**Implemented**	`admin-logic.test.ts` ; E2E
FR-ADM-02	The dashboard shall show a prioritised "needs attention" list: paid orders needing a refund, payments with wrong amount, paid orders to buy, new link requests, stale orders (5+ days), imported items to review, stopped sources, failed messages, unpaid orders over 24 hours, and an exchange-rate gap.	M	**Implemented**	`admin-logic.test.ts`

ID	Requirement	Pri	Status	Verified by
FR-ADM-03	Staff shall be able to set the exchange rate and markup, the service charge, the minimum order, the site name and the support WhatsApp number, with changes to the rate recorded in a history.	M	**Implemented**	`admin-logic.test.ts` ("exchange rate"); `admin.test.ts` ; E2E
FR-ADM-04	Staff shall be able to create, edit, hide and price shipping methods and rate cards, with validation (for example ascending brackets).	M	**Implemented**	`admin-parse.test.ts` ; `admin.test.ts`
FR-ADM-05	Staff shall be able to create, edit, hide and delete delivery areas; the last active area shall not be deletable; orders shall keep the area name and fee charged.	M	**Implemented**	`shop-delete.test.ts` ; E2E
FR-ADM-06	Staff shall be able to choose one of 15 colour themes for the whole shop.	S	**Implemented**	`themes.test.ts` ; E2E
FR-ADM-07	Staff shall be able to enter, switch on, test and clear provider keys; keys shall be encrypted at rest, shown masked, never logged, and overridden by environment settings; a readiness summary shall list what is missing.	M	**Implemented**	`integrations.test.ts` ; `secrets.test.ts`
FR-ADM-08	The admin shall record every administrative action and sign-in in an activity log naming the person, searchable by staff with the right.	M	**Implemented**	E2E (audit actors checked); inspection
FR-ADM-09	The exchange-rate feed policy shall be manual, suggest or automatic, with a maximum automatic move (default 5%) and an alert gap (default 3%); automatic moves beyond the limit shall wait for staff.	S	**Implemented**	`fx-api.test.ts`
FR-ADM-10	The admin shall not require a technical user: plain language, confirmation for destructive actions (delete shop, area, account, source), and clear errors.	S	**Implemented**	Inspection; E2E

4.12 Staff accounts and access control (FR-STF)

ID	Requirement	Pri	Status	Verified by
FR-STF-01	There shall be one **super admin**, authenticated by the server-held `ADMIN_PASSWORD` at a separate developer sign-in, not stored in the database, who can do everything and is the only person able to manage staff accounts.	M	**Implemented**	`admin-guards.test.ts` ; E2E
FR-STF-02	The super admin shall be able to create staff accounts (name, email, first password, role), see them, change name, role and rights, switch them off and on, reset their password, and delete them (with confirmation).	M	**Implemented**	`admin-users.test.ts` ; E2E
FR-STF-03	Each staff account shall hold a set of **rights**; roles (Manager, Operations, Customer support, Catalogue editor, Finance, Read-only) shall be presets, and the super admin shall be able to tick exact rights ("Custom"). A change right shall imply the matching view right.	M	**Implemented**	`permissions.test.ts`
FR-STF-04	The right to manage staff accounts shall not be grantable to staff.	M	**Implemented**	`permissions.test.ts` ; `admin-guards.test.ts`

ID	Requirement	Pri	Status	Verified by
FR-STF-05	**Every** admin page, admin server action and the orders download shall check the specific right on the server for each request; the menu shall show only permitted pages and other pages shall show "No access".	M	**Implemented**	`admin-guards.test.ts` ; E2E "support account sees and does only what its role allows"
FR-STF-06	A new or reset staff account shall have to choose its own password (at least 10 characters) before any other admin page opens.	M	**Implemented**	`admin-users.test.ts` ; E2E
FR-STF-07	Switching an account off, changing its rights or resetting its password shall end its open sessions at once.	M	**Implemented**	`admin-users.test.ts` ; E2E "switching a staff account off…"
FR-STF-08	Staff shall not be able to give themselves more access; a staff member shall be able to change only their own password.	M	**Implemented**	`admin-guards.test.ts`
FR-STF-09	Admin sign-in shall be rate-limited (5 failures per place and 8 per email per 15 minutes), with the same timing for unknown emails.	M	**Implemented**	`auth.test.ts` ; `admin-users.test.ts`
FR-STF-10	Staff actions shall be recorded under the person's name and email.	M	**Implemented**	E2E (audit actors)
FR-STF-11	Sessions shall use signed, HttpOnly, SameSite cookies, 8 hours, tamper-evident and bound to the account's session version.	M	**Implemented**	`auth.test.ts`
FR-STF-12	Staff sign-in shall support two-step verification.	S	**Not implemented**	–
FR-STF-13	New staff shall receive an email invitation to set a password.	C	**Not implemented (the super admin gives the first password)**	–

4.13 System and operations (FR-SYS)

ID	Requirement	Pri	Status	Verified by
FR-SYS-01	`/api/health` shall report whether the server is up and the database readable (`{"ok":true}` or 503) without exposing details.	M	**Implemented**	Inspection; E2E
FR-SYS-02	Cron endpoints (`/api/cron/messages` , `/fx` , `/ingest`) shall answer 404 until a secret is set and then require a bearer secret.	M	**Implemented**	E2E "unsigned webhook and unauthenticated cron are refused"
FR-SYS-03	The database schema shall be created and migrated automatically at start without losing data, including rebuilding a table when a rule must change.	M	**Implemented**	`source-kinds-migration.test.ts` ; `shop-logo.test.ts` ; `link-orders.test.ts`
FR-SYS-04	Deleting all shops shall not cause the starter data to be re-created at restart.	M	**Implemented**	`shop-delete.test.ts`
FR-SYS-05	The system shall serve security headers (frame denial, no-sniff, referrer policy, permissions policy, HSTS) and a `robots.txt` that disallows private areas.	M	**Implemented**	Inspection
FR-SYS-06	The public address shall come from configuration, never from request headers.	M	**Implemented**	Inspection (`app-url.ts`)

ID	Requirement	Pri	Status	Verified by
FR-SYS-07	Secrets shall never appear in logs or pages.	M	**Implemented**	`integrations.test.ts` ; inspection
FR-SYS-08	A page shall explain the importer to shop owners (`/bot`).	S	**Removed** (owner's decision; the importer's user agent links to the site's home page instead)	E2E checks the page is gone

---

5. Verification and traceability

5.1 Verification methods

Method	Meaning
Test	An automated check: a unit or database test (`npm test` , 321 tests in 41 files) or a step of the end-to-end browser run (`npm run e2e` , 40 steps).
Inspection	Reading the code or screen. Used where a check cannot be automated sensibly (for example wording).
Demonstration	Doing it by hand on the live site. Required for real payments, real shop pages and real message delivery (see 5.4).

5.2 Traceability: requirement areas to tests

Area	Requirement IDs	Automated checks
Browsing and search	FR-BRW	`browse.test.ts` , `discovery.test.ts` , `department-icons.test.ts` , E2E (home, search, suggestions)
Cart	FR-CRT	`admin.test.ts` , E2E (add to cart, cart total)
Pricing	FR-PRC	`pricing.test.ts` , `admin.test.ts` , `admin-parse.test.ts` , E2E (checkout total equals cart)
Accounts	FR-ACC	`customers.test.ts` , `customer-session.test.ts` , `password.test.ts` , `account-orders.test.ts` , `throttle.test.ts` , E2E (register, account)
Orders	FR-ORD	`order-status.test.ts` , `admin.test.ts` , `admin-logic.test.ts` , `account-orders.test.ts` , E2E (checkout, pay, admin moves order)
Payments	FR-PAY	`payments.test.ts` , E2E (demo payment)
Notifications	FR-MSG	`outbox.test.ts` , `templates.test.ts` , `phone.test.ts`
Reviews and wishlist	FR-REV	`discovery.test.ts` , `account-orders.test.ts` , E2E (wishlist)
Link orders	FR-LNK	`link-orders.test.ts` , `link-auto.test.ts` , `link-submit.test.ts` , E2E (link request to order, automatic quotes, found-link flow)
Catalogue	FR-CAT	`ingest/net.test.ts` , `parse.test.ts` , `field-map.test.ts` , `run.test.ts` , `ebay.test.ts` , `diffbot.test.ts` , `shopify.test.ts` , `woocommerce.test.ts` , `file-import.test.ts` , `source-kinds-migration.test.ts` , `seed.test.ts` , `shop-delete.test.ts` , `shop-logo.test.ts` , `uploads.test.ts` , `secrets.test.ts` , E2E (sources, shops, uploads)

Area	Requirement IDs	Automated checks
Administration	FR-ADM	`admin-logic.test.ts`, `admin.test.ts`, `integrations.test.ts`, `fx-api.test.ts`, `themes.test.ts`, `csv.test.ts`, E2E (every admin page, themes, delivery areas)
Staff and access	FR-STF	`admin-users.test.ts`, `permissions.test.ts`, `auth.test.ts`, `admin-guards.test.ts`, E2E (staff account journey)
System	FR-SYS	`source-kinds-migration.test.ts`, `shop-delete.test.ts`, E2E (health, cron, webhooks)
Phone layouts	IR-UI-01 to 03	E2E (shop fits a phone, admin fits a phone)

5.3 End-to-end acceptance journeys (automated)

The browser run is the system's **acceptance test**. Each step below must pass for a release:

1. Protected pages redirect guests; unsigned webhooks and unauthenticated cron calls are refused.
2. Search suggests items as you type; results page finds the item.
3. A guest adds two trainers to the cart; the cart total is right; checkout asks them to sign in; they register and return with the cart intact.
4. They pay (demo payment) and the order shows in their account with an updates entry.
5. The admin signs in (wrong password refused); every admin page loads; the admin moves the order; the customer sees the change.
6. Changing the service charge and exchange rate reaches the storefront; an invalid tier setup is rejected clearly.
7. Catalogue sources need permission and refuse internal addresses; a source can be created and removed; the eBay, Diffbot, Shopify and file-import forms work.
8. A shop and a delivery area can be added and deleted only after confirmation; a shop logo uploads and shows; fake images are refused.
9. A colour theme chosen in the admin reaches the storefront.
10. A link request is quoted, paid and appears as an ordinary order; automatic quotes price an ordinary request and leave a dear one for staff; a found link goes straight to the customer's request.
11. A staff account is created, must change its password, sees only its role's pages, is blocked elsewhere, cannot change orders or download exports, and is signed out when switched off.
12. The shop and the admin fit a phone with no sideways scrolling.

5.4 Not verified automatically (must be demonstrated)

- Real payments with each gateway, and real webhook delivery.
- Reading a real shop's page or feed (the test environment cannot reach retailer sites).
- Real SMS, WhatsApp and email delivery and template approvals.
- Behaviour on real iPhone and Android devices.
- Behaviour under load; recovery from a restored backup. See Testing → manual checklist.

5.5 Acceptance criteria for release

All automated checks pass (`npm run lint && npm run typecheck && npm test && npm run e2e`); the manual checklist is completed; a backup has been taken and restored once; at least one payment gateway is configured and has processed a real small order end to end.

6. Non-functional requirements

Status for these is **Implemented**, **Partial** or **Target** (a goal that has not been measured).

6.1 Performance

ID	Requirement	Pri	Status
NFR-PER-01	Pages shall render from live data on every request; list and product pages should respond within 1 second at the 95th percentile for one small shop (up to a few thousand items and a few hundred orders a day) on the Starter instance.	S	**Target (not load-tested; the database is local and queries are indexed)**
NFR-PER-02	Search suggestions shall respond fast enough to feel instant and shall be limited to 120 requests per visitor per minute.	S	**Implemented (limit); latency not measured**
NFR-PER-03	The catalogue importer shall not slow shopping: runs are sequential, paced, size-limited, and a source run never holds a database transaction across a network wait.	M	**Implemented**
NFR-PER-04	Pages should be light for mobile data: no external fonts, scripts or trackers; images lazy-loaded.	S	**Implemented**

6.2 Reliability and availability

ID	Requirement	Pri	Status
NFR-REL-01	Order creation and payment confirmation shall be atomic and idempotent: no half-created orders; a repeated webhook shall have no further effect.	M	**Implemented**
NFR-REL-02	A messaging or provider failure shall never break an order; messages shall retry.	M	**Implemented**
NFR-REL-03	The system shall start cleanly after a restart or redeploy, applying schema changes automatically.	M	**Implemented**
NFR-REL-04	The target availability is that of a single always-on instance (no redundancy). Planned maintenance interruption is a few minutes per deploy.	S	**Partial (no failover by design; see DC-1)**
NFR-REL-05	The importer shall fail safe: a bad feed shall never wipe the catalogue (removal only from complete feeds and only if at least half the items remain).	M	**Implemented**

6.3 Security (summary; full detail in Security and privacy)

ID	Requirement	Pri	Status
NFR-SEC-01	Passwords shall be hashed with scrypt; session tokens and reset tokens stored hashed.	M	**Implemented**
NFR-SEC-02	Stored secrets (provider keys, feed addresses) shall be encrypted with AES-256-GCM.	M	**Implemented**
NFR-SEC-03	Cookies shall be HttpOnly, SameSite=Lax and Secure in production; customer cookies use the `__Host-` prefix.	M	**Implemented**
NFR-SEC-04	All database access shall use bound parameters.	M	**Implemented**
NFR-SEC-05	Authentication and sensitive actions shall be rate-limited.	M	**Implemented**
NFR-SEC-06	Uploaded files shall be validated by content and served so they cannot execute.	M	**Implemented**

ID	Requirement	Pri	Status
NFR-SEC-07	The server shall not be usable to reach internal networks (SSRF protection on every outbound fetch it makes on a user's behalf).	M	**Implemented**
NFR-SEC-08	Access shall be least-privilege by right, enforced on the server per request, and every admin action audited.	M	**Implemented**
NFR-SEC-09	A Content-Security-Policy shall protect the main pages.	S	**Not implemented**
NFR-SEC-10	Rate limits shall be shared across instances.	C	**Not implemented (single instance only)**

6.4 Usability and accessibility

ID	Requirement	Pri	Status
NFR-USE-01	A first-time shopper shall be able to find an item, see its full cost and pay without instructions.	M	**Implemented (design); not user-tested**
NFR-USE-02	Destructive admin actions shall need explicit confirmation.	M	**Implemented**
NFR-USE-03	Error messages shall say what is wrong and what to do.	S	**Implemented**
NFR-USE-04	Forms shall have labelled fields, visible focus and keyboard operation.	S	**Implemented**
NFR-USE-05	The site shall meet WCAG 2.1 AA.	S	**Partial (no formal audit)**
NFR-USE-06	The interface shall be in English; amounts in GHS and GBP.	M	**Implemented**

6.5 Compatibility and portability

ID	Requirement	Pri	Status
NFR-CMP-01	Support current Chrome, Edge, Firefox and Safari (desktop and mobile).	M	**Partial (tested in Chrome and an emulated phone; other browsers by design only)**
NFR-CMP-02	Run in a Docker container on any host with a persistent disk (Render, Fly.io, a VPS).	M	**Implemented**
NFR-CMP-03	The database shall be a single portable file.	M	**Implemented**

6.6 Maintainability and operability

ID	Requirement	Pri	Status
NFR-MNT-01	Code shall pass lint and type checks; logic shall have automated tests; a guard test shall prevent unprotected admin pages.	M	**Implemented**
NFR-MNT-02	Pricing, access checks and the network layer shall each live in one place.	M	**Implemented**
NFR-MNT-03	Documentation shall describe use, operation, architecture, data, security and requirements.	M	**Implemented (this set)**
NFR-OPS-01	A health endpoint, logs without secrets, and an in-admin attention list shall make problems visible.	M	**Implemented**
NFR-OPS-02	Backups shall be possible while running (SQLite backup API) and restorable.	M	**Implemented (procedure documented; the schedule is the operator's)**

6.7 Backup and recovery targets

ID	Requirement	Status
NFR-BKP-01	The operator shall back up the database and uploads at least daily and keep a copy off the server. Recovery point equals the backup interval.	**Operator duty (not automated by the software)**
NFR-BKP-02	A restore shall be rehearsed before launch. Target recovery time: within a working day.	**Operator duty**

6.8 Capacity and scalability

The system is sized for **one small business**: one instance, one disk, hundreds of orders a day at most. It is **not** designed for horizontal scaling. Growing beyond this requires replacing SQLite with a client-server database, moving timers to a worker, and sharing rate limits (see Appendix B).

6.9 Legal and regulatory (not provided by software)

The operator is responsible for consumer-protection terms and refund policy, VAT and import duty, payment-service licensing, data-protection registration and lawful handling of personal data (Ghana Data Protection Act and, where relevant, UK/EU rules), and for the right to display imported product data and images. The software provides tools (audit log, account deletion, access control) but not legal compliance.

---

7. Data requirements

ID	Requirement	Status
DR-01	Persistent data shall live in one SQLite database (WAL mode, foreign keys on) plus an uploads folder next to it. See Data model.	**Implemented**
DR-02	Money shall be stored as integer minor units.	**Implemented**
DR-03	An order shall be self-contained: it stores customer, delivery, area, shipping, amounts, rate and each item as at purchase; deleting a shop, item or area shall not change it.	**Implemented**
DR-04	Secrets shall be encrypted; passwords and tokens hashed.	**Implemented**
DR-05	Times shall be stored in UTC.	**Implemented**
DR-06	The audit log shall be append-only through the application.	**Implemented**
DR-07	Schema changes shall be forward-only, additive and applied automatically; a rule change shall rebuild the table keeping rows.	**Implemented**
DR-08	Personal data shall be limited to what is needed (name, phone, optional email, addresses, orders, sessions, staff details).	**Implemented**
DR-09	Retention: orders, link requests and the activity log are kept until the operator removes them; the system has no automatic deletion.	**Partial (operator-defined; see Appendix B)**
DR-10	A customer's personal data shall be exportable on request.	**Not implemented (done by hand from the database)**

Entities (all in the Data model): shops, products, carts and lines, orders with items, events, tracking, costs and payments, link requests, customers with sessions, addresses, resets, wishlist and reviews, staff accounts, audit log, settings and integration settings, shipping methods, delivery zones, exchange-rate history, messages, webhook events, catalogue sources, imported items and runs.

Indicative volumes (planning assumptions): up to ~5,000 items, ~500 orders a day, ~50,000 customers, ~1 GB total for the first year including photos. Photos are the main growth.

---

8. Business rules

ID	Rule
BR-01	**Customer total** = items + service charge + shipping to Ghana + delivery in Ghana. Duties and taxes in Ghana are excluded.
BR-02	**Effective rate** = rate × (1 + markup%). Items are converted at the effective rate.
BR-03	**Minimum order**: items only, in pounds; default £10. Applies to link orders too.
BR-04	**Order status path**: Payment received → Buying from the UK shop → Bought from the UK shop → Received at our UK address → On its way to Ghana → Clearing customs → Out for delivery → Delivered.
BR-05	**Only a gateway-confirmed payment** with matching amount and currency makes an order *Payment received*. Staff cannot mark an order paid.
BR-06	Staff move an order **one step forward**; they may **cancel** up to *Buying from the UK shop*; a **paid and cancelled** order may be marked **Refunded** after the refund is made in the gateway.
BR-07	**Nothing is bought before payment is confirmed.**
BR-08	A **review** is allowed only for an item the customer received (order *Delivered*), once per item.
BR-09	**No discount claims**: customers see only the shop's current price (in pounds and cedis). The shop never shows a "was" price, a percentage off, or a saving.
BR-10	**Imported prices** are accepted only in pounds; an item is held for review if the price is under 50p, over £10,000, jumps by more than the source's limit (default 40%), the name is under 3 characters or there is no link back.
BR-11	**Disappearing items**: hidden only when missing from a *complete* feed and at least half of the known items remain; items not refreshed within the stale window (default 14 days) are hidden.
BR-12	**A source needs permission**: it cannot be switched on until the operator confirms the shop's terms or a licence.
BR-13	**The importer stops on refusal** (401, 403, 429, 451 or a verification page) and pauses that source for 24 hours; it never tries to evade.
BR-14	**A quote** is held for the days set (1 to 30, default 3), has one private link, can be changed until used, and produces **at most one order**.
BR-15	**Automatic quotes** apply only when the admin allows, only up to the automatic limit (default £150 per item), and a customer-typed price always carries the safety margin (default 5%).
BR-16	**Deleting a shop or delivery area** never changes placed orders; the **last active delivery area** cannot be deleted.
BR-17	**Staff accounts** are created only by the super admin; a staff member can never grant rights; new or reset accounts must choose their own password; switching off or changing an account signs it out at once.
BR-18	**Notifications** go out only on channels the customer chose, the admin enabled for that status, and a configured provider supports.
BR-19	**Cancelled before shipment** is the customer's window to withdraw; after the UK shop has bought the item it normally cannot be cancelled. (Policy; not enforced by software beyond BR-06.)
BR-20	**Prices shown are guidance until paid**: the server recomputes every amount at order creation.

---

9. Use cases

UC-01 Browse and buy a listed item

- **Actor:** Customer. **Pre:** none (sign-in required at checkout). **Related:** FR-BRW, FR-CRT, FR-PRC, FR-ORD, FR-PAY.
- **Main flow:** 1. Customer finds an item (browse or search). 2. Chooses options and quantity, **Add to cart**. 3. Opens the cart; sees totals in cedis and pounds. 4. **Checkout**: signs in or registers; chooses area and shipping; enters address; chooses notifications. 5. **Place order and pay**; chooses a gateway; pays on its page. 6. The system confirms payment, sets *Payment received*, sends a message. 7. Customer follows tracking.
- **Alternatives:** payment fails → order stays awaiting payment, customer retries. Below minimum → told how much more is needed. Item or option missing → cannot add.
- **Post:** an order exists with status *Payment received*; staff see it as "waiting to be bought".

UC-02 Paste a link and buy (automatic quote)

- **Actor:** Customer. **Related:** FR-LNK-01 to -03, -07.
- **Main flow:** 1. Customer pastes a product link. 2. The system reads the name and price from the shop's page (allowed) and shows pounds and cedis. 3. Customer enters quantity, kind of item and size/colour; taps **Get my full price and pay**. 4. The server re-reads the page, applies the rules, quotes, and opens the quote page. 5. Customer signs in if needed, sees the full cost, chooses delivery, pays. 6. As UC-01 from step 5.
- **Alternatives:** page unreadable or price above the limit → request waits for staff (UC-03). Quote expired → asks for a fresh one.

UC-03 Link request quoted by staff

- **Actors:** Customer, Staff with *Handle link requests*. **Related:** FR-LNK-04 to -06, -08, -09.
- **Main flow:** 1. A request arrives (listed in **Link requests** and on the dashboard). 2. Staff open the link on the shop; confirm price and stock. 3. Staff enter UK price, weight, days and a note; **Send quote**. 4. The customer is messaged a private link and sees it in their account. 5. Customer pays (UC-01 step 5). 6. The request becomes *Ordered* and links to the order.
- **Alternatives:** staff reject the request → customer sees "could not get this item". Staff change the quote → same link keeps working.

UC-04 Fulfil an order

- **Actor:** Staff with *Update orders*. **Related:** FR-ORD-07 to -09, -12, FR-MSG.
- **Main flow:** 1. Staff open a *Payment received* order. 2. Buy the items from the UK shop (outside the system). 3. Mark *Buying…* then *Bought…* with the shop's order reference as a note. 4. When received in the UK, add tracking and mark *Received at our UK address*. 5. On shipping, add tracking and mark *On its way to Ghana*; then *Clearing customs*, *Out for delivery* (with courier reference), *Delivered*. 6. Record real costs to see margin.
- **Post:** the customer saw each step and received the configured messages.

UC-05 Cancel and refund

- **Actor:** Staff with *Update orders*. **Related:** FR-ORD-07, BR-06.
- **Main flow:** 1. Customer asks to cancel before buying. 2. Staff **Cancel** the order. 3. The dashboard shows "needs a refund" (paid orders). 4. Staff refund in the gateway's dashboard. 5. Staff mark the order **Refunded**;

the customer is messaged.

UC-06 Fill the catalogue from a source

- **Actor:** Staff with *Manage catalogue sources*. **Related:** FR-CAT-10 to -34.
- **Main flow:** 1. Staff create a source (kind, address or searches), confirm permission. 2. **Check this setup first** to preview. 3. **Create source** and **Run now**. 4. New items go live; odd ones wait in **Import review**. 5. The scheduler refreshes prices and stock and hides stale items.
- **Alternatives:** the shop refuses → the run stops, the source pauses 24 hours and shows why.

UC-07 Manage staff access

- **Actor:** Super admin. **Related:** FR-STF.
- **Main flow:** 1. Super admin signs in at the developer sign-in. 2. Creates an account with a role and first password. 3. The staff member signs in, chooses their own password, and sees only their pages. 4. Later the super admin changes rights, resets the password or switches the account off (immediate sign-out).

UC-08 Set prices and delivery

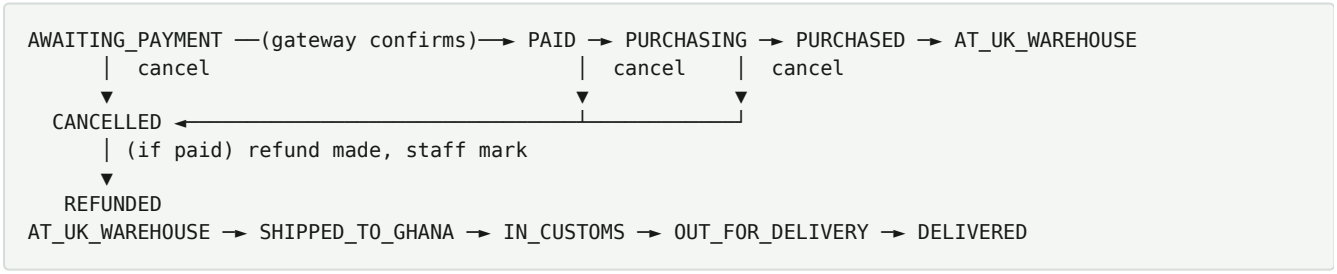
- **Actor:** Staff with *Change prices and delivery*. **Related:** FR-PRC, FR-ADM-03 to -05.
- **Main flow:** 1. Open **Pricing**: set rate, markup, service charge, minimum order. 2. Open **Shipping**: rate cards. 3. Open **Delivery areas**: areas and fees. 4. Check "What customers pay now". 5. Save.

UC-09 Customer recovers a forgotten password

- **Actor:** Customer. **Related:** FR-ACC-04.
- **Main flow:** 1. **Forgot password**. 2. Enters phone or email. 3. Receives a link (email, else SMS) valid 60 minutes. 4. Sets a new password; is signed in; other devices are signed out.
- **Alternative:** no message arrives → staff create a one-time link for the customer.

State models

Order status



---

10. Constraints, assumptions, dependencies and risks

10.1 Constraints

See 2.5 (DC-1 to DC-6). Additionally: the importer's refusal to evade blocks is a deliberate **business constraint**, not a defect (FR-CAT-33).

10.2 Risks

ID	Risk	Impact	Mitigation in the system	Residual
R-1	A retailer's terms forbid collecting or showing its data, or it blocks the importer.	Legal exposure; missing products.	Permission confirmation, `robots.txt`, stop-on-refusal, affiliate feeds, link orders.	Operator must check terms and licences.
R-2	A link-order price read or typed is wrong (several prices on a page, a typo, an old price).	Margin loss on a paid order.	Quote validity, safety margin, automatic limit, per-order banner, staff verify before buying, cancel and refund.	Verification before buying is manual (FR-LNK-11).
R-3	Exchange-rate movement between quote and purchase.	Margin loss.	Markup on the rate, optional feed with alert and limits, quote expiry.	Operator discipline on the rate.
R-4	Data loss (disk failure, deletion).	Loss of orders and customers.	Backup API, documented procedure, restore rehearsal.	**Backups are the operator's duty.**
R-5	Leak of keys or the super admin password.	Fraud, data exposure.	Encryption at rest, masked display, separate encryption key, rotation runbook, audit log.	No two-step sign-in.
R-6	Payment mismatch or fraud.	Shipping unpaid goods.	Amount and currency verification, signed webhooks, wrong-amount alert.	Gateway-side fraud checks are the gateway's.
R-7	Single instance outage.	Shop unavailable.	Health check, auto-restart by the host.	No redundancy by design.
R-8	Staff misuse of access.	Data or price tampering.	Least-privilege rights, audit log, immediate switch-off.	Trust in the super admin.
R-9	Customs duty, VAT or consumer-law non-compliance.	Fines, disputes.	Total excludes duty and says so.	Needs professional advice (A-5).
R-10	Image or data licensing breaches.	Takedown claims.	Source terms confirmation; images linked from source.	Operator responsibility (A-3).
R-11	Third-party API changes or outages.	Features stop.	Isolated adapters, clear errors, retries, manual fall-backs.	Provider dependence.
R-12	SQLite or in-process timers limit growth.	Scaling ceiling.	Documented single-instance rule.	Re-architecture needed for scale.

Appendix A: Requirement status summary

Counted from the requirement tables above (functional, interface, non-functional and data requirements).

Area	Implemented	Partial, target or operator duty	Not implemented	Total
DR	8	1	1	10
FR-ACC	10	0	1	11
FR-ADM	10	0	0	10
FR-BRW	12	0	0	12
FR-CAT	20	0	0	20
FR-CRT	6	0	0	6
FR-LNK	14	0	1	15
FR-MSG	8	0	0	8

Area	Implemented	Partial, target or operator duty	Not implemented	Total
FR-ORD	14	0	2	16
FR-PAY	8	0	1	9
FR-PRC	10	0	0	10
FR-REV	4	0	0	4
FR-STF	11	0	2	13
FR-SYS	8	0	0	8
IR-EX	11	0	0	11
IR-UI	8	1	0	9
NFR-BKP	0	2	0	2
NFR-CMP	2	1	0	3
NFR-MNT	3	0	0	3
NFR-OPS	2	0	0	2
NFR-PER	3	1	0	4
NFR-REL	4	1	0	5
NFR-SEC	8	0	2	10
NFR-USE	5	1	0	6
All	**185**	**8**	**10**	**203**

Appendix B: Gaps and future work

Items below are **not implemented** or only **partial**. They are the honest edge of the system today, with a suggested priority.

#	Gap	Related	Suggested priority
1	Two-step sign-in for staff and the super admin	FR-STF-12	High before staff grow in number
2	Phone or email verification at sign-up	FR-ACC-10	High (stops fake accounts and bad contact details)
3	Automatic verification of the shop's price at purchase time for link orders	FR-LNK-11	High (protects margin)
4	Refund started from the admin through the gateway	FR-PAY-09	Medium
5	Customer self-service cancel before buying	FR-ORD-14	Medium
6	Receipts or invoices as downloadable documents	FR-ORD-15	Medium
7	Email invitation for new staff	FR-STF-13	Low
8	Content-Security-Policy on the main pages	NFR-SEC-09	Medium
9	Shared rate-limit store, database server and worker for more than one instance	NFR-SEC-10, DC-1	Only if growth demands it

#	Gap	Related	Suggested priority
10	Data export and retention tooling for privacy requests	DR-09, DR-10	Medium
11	Formal accessibility audit (WCAG 2.1 AA)	IR-UI-09, NFR-USE-05	Medium
12	Load testing and measured performance targets	NFR-PER-01	Medium
13	Testing on real iPhone, Android and other browsers	NFR-CMP-01	High, do before launch
14	Volumetric weight for items	FR-PRC-04	Low
15	Multiple languages (for example Twi)	NFR-USE-06	Low
16	Returns and disputes handling	– (out of scope today)	As the business needs
17	Inventory or stock counts for items not from a live source	–	Low (the business holds no stock)

Appendix C: Glossary

Term	Meaning
Catalogue source	A place the importer is allowed to read a shop's products from.
Chargeable weight	The larger of actual and volumetric weight, used to price shipping.
Effective rate	Exchange rate plus the admin's markup; the rate customers pay.
Gateway	A payment provider: Stripe, Paystack or Flutterwave.
Held item	An imported item waiting for staff review.
Link order	An order for an item the customer found elsewhere and sent as a link.
Outbox	The queue of messages awaiting delivery, with retries.
Quote	The UK price and weight of one item, with a private pay link and expiry.
Rate card	A shipping price list by weight.
Right	One thing a staff account may do.
Role	A preset set of rights.
Service charge	The operator's fee for buying on the customer's behalf.
Staff account	An admin sign-in created by the super admin with limited rights.
Super admin	The developer's sign-in using `ADMIN_PASSWORD` ; unlimited and the only one managing staff.
SRS	Software Requirements Specification (this document).
WAL	SQLite's write-ahead log mode.

Appendix D: Revision history

Version	Date	Change
1.0	7 October 2026	First complete, as-built SRS written from the finished system, with every requirement given a status and a means of verification.
1.1	9 October 2026	Added FR-LNK-12 to -15 (ordering from Amazon UK by link, hand-off search, bookmarklet, phone Share menu, requests described in words).

To keep this document true, update the status of a requirement in the same change that implements it, and add new requirements with the next free number in their area.